

Task 2 Password Policy

By **Stephen Reilly** | *Security Policy Analysis Series*

Objective

Create a comprehensive Password Policy aligned with current security best practices and NIST guidelines.

Scenario

Company: SecureBank Financial Services

Regulation: Must comply with PCI-DSS, SOX, and FFIEC guidelines

Systems:

- Core banking system (critical)
- Customer portal
- Employee workstations
- Administrative systems
- Development environment

Requirements

Create a Password Policy that includes:

1. **Password Requirements** - length, complexity, prohibited passwords
2. **Password Management** - change/reset procedures, lockout, timeouts
3. **MFA** - where required, approved methods
4. **Storage** - hashing requirements, password managers
5. **Privileged Accounts** - enhanced requirements, PAM

Deliverables

1. Complete Password Policy using the template
2. Technical standards (can be a separate Standards document)

PASSWORD POLICY

SecureBank Financial Services

Document Control

Field	Value
Policy ID	POL-SEC-001
Version	1.0

Field	Value
Effective Date	2026-06-22
Review Date	2027-06-22
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Security Committee
Classification	Internal

1. Purpose

This policy establishes requirements for password creation, management, storage, and authentication controls to ensure the confidentiality, integrity, and availability of SecureBank's information systems and protect customer data, financial assets, and sensitive business information.

This policy supports compliance with:

- **PCI-DSS v4.0** (Payment Card Industry Data Security Standard)
 - **SOX** (Sarbanes-Oxley Act Section 404)
 - **FFIEC** (Federal Financial Institutions Examination Council) Authentication Guidelines
-

2. Scope

2.1 Applicability

This policy applies to:

- All employees
- Contractors and consultants
- Third-party vendors with system access
- Temporary staff and interns
- Administrative and privileged users (additional requirements in Section 3.3)

2.2 Systems/Assets Covered

- Core banking system (critical infrastructure)
- Customer portal and online banking interfaces
- Employee workstations (Windows, macOS, Linux)
- Administrative systems and domain controllers
- Development and testing environments
- Cloud-based services accessed by SecureBank personnel
- Mobile devices accessing corporate resources
- API endpoints and application authentication points

2.3 Exclusions

- Public-facing systems that do not authenticate users
- Service accounts managed through automated credential rotation (documented separately)

- Legacy systems scheduled for decommissioning within 90 days (requires exception per Section 7)
-

3. Policy Statements

3.1 Password Requirements

All user passwords must meet the following standards to prevent unauthorized access while maintaining usability.

Requirements:

- **Minimum Length:** 14 characters for standard users; 16 characters for privileged accounts
- **Complexity:** Must contain characters from at least 3 of 4 categories: uppercase letters, lowercase letters, numbers, special characters
- **Prohibited Passwords:** Cannot contain usernames, company name "SecureBank", common dictionary words, previously compromised credentials (checked against HaveIBeenPwned database or equivalent)
- **No Password History:** Users cannot reuse any of their last 12 passwords
- **Passphrases Permitted:** Multi-word passphrases meeting minimum length requirements are acceptable and encouraged for memorization
- **NIST Guidance Applied:** Periodic mandatory password changes are NOT required unless compromise is suspected or indicators of breach exist

Note: Per NIST SP 800-63B §5.1.1.2, periodic password expiration should be discontinued unless there is evidence of compromise. However, PCI-DSS §8.3.1 requires password change every 90 days for certain administrative functions—these exceptions are documented below.

3.2 Password Management & Account Protection

Password lifecycle management procedures ensure consistent security across all systems.

Requirements:

- **Account Lockout:** After 5 consecutive failed login attempts, account locks for 30 minutes or until administrator unlock
- **Session Timeout:** Automatic logout after 15 minutes of inactivity for core banking; 30 minutes for other systems
- **Password Reset:** Self-service reset available through secure MFA-verified channel; verification via email and secondary factor
- **Initial Password:** Randomly generated, marked as "change on first login," expires after 24 hours if not changed
- **Password Managers:** All employees REQUIRED to use approved Bitwarden Enterprise password manager; storing passwords in browsers or documents is prohibited
- **Sharing Prohibited:** Credentials shall never be shared between individuals, even temporarily

3.3 Multi-Factor Authentication (MFA) Requirements

Multi-factor authentication significantly reduces risk of credential-based attacks.

Requirements:

- **Where Required:**
 - All employee access to core banking system (MANDATORY)
 - All remote access via VPN or remote desktop (MANDATORY)
 - All administrative and privileged accounts (MANDATORY)
 - Customer portal access (MANDATORY, implemented phase-wise per regulatory timeline)
 - Development environment access containing production-like data (MANDATORY)
 - Email and collaboration tools (RECOMMENDED but required by Q3 2026)
- **Approved MFA Methods:**

Priority	Method	Description
Tier 1	FIDO2/WebAuthn hardware keys	Most secure; recommended for privileged accounts
Tier 1	OAuth2/OIDC push notifications	Via approved authenticator apps (Bitwarden, Duo, Microsoft Authenticator)
Tier 2	TOTP time-based codes	Acceptable for standard users; not for privileged access
Tier 3	SMS/voice call	Permitted only when no alternative exists; requires compensating controls
Not Approved	SMS OTP for privileged accounts, static backup codes as primary method	

- **OAuth2 Integration:** All internal applications implementing SSO must use OAuth2/OIDC protocols; session tokens expire after configurable duration (default: 1 hour inactive, 12 hours absolute max)

3.4 Password Storage & Hashing

Technical implementation of credential storage protects against theft and brute-force attacks.

Requirements:

- **Hashing Algorithm:** bcrypt (cost factor ≥ 12), Argon2id, or PBKDF2-SHA-256 (iterations $\geq 600,000$); MD5, SHA-1, unsalted hashes strictly prohibited
- **Salt Requirements:** Unique salt per password, minimum 16 bytes, stored with hash
- **Bitwarden Integration:** All employee passwords stored in Bitwarden Enterprise vault with end-to-end encryption (AES-256-GCM + PBKDF2-SHA-256 client-side key derivation)
- **Vault Access:** Master password separate from corporate credentials; recovery organization key stored with CISO office
- **Database Security:** Application-level encryption for password fields in backend databases; regular cryptographic audits
- **API Keys/Tokens:** Stored in secret management solution (not human-accessible password stores); rotated quarterly

- **No Plain Text:** Passwords shall never appear in logs, error messages, emails, or documentation

3.5 Privileged Accounts & PAM

Privileged access management addresses elevated risk associated with administrative credentials.

Requirements:

- **Enhanced Password Requirements:** 16+ characters; changed immediately upon role assignment or suspicion of compromise
- **Just-in-Time Access:** Privileged elevation granted for limited duration (maximum 8 hours); automatic revocation after completion
- **Segregation of Duties:** No single individual may possess all privileges necessary to bypass controls; dual approval for critical changes
- **Session Recording:** Full audit logging of all privileged sessions; recordings retained for 1 year minimum
- **Dedicated Admin Accounts:** Separate credentials for administrative tasks vs. daily operations; different passwords required
- **Privileged Access Workstation (PAW):** High-risk administrative activities conducted from hardened, isolated systems
- **PAM Solution:** Integration with enterprise Privileged Access Management tool (e.g., Bitwarden Secrets Manager, CyberArk, or similar) for automated credential rotation and monitoring
- **Quarterly Access Reviews:** Privileged account assignments reviewed and re-certified by department heads every 90 days

4. Roles and Responsibilities

Role	Responsibilities
Executive Management	Approve policy, allocate budget/resources, demonstrate security commitment, participate in access reviews
CISO/Security Team	Maintain policy, implement controls, monitor compliance, respond to violations, conduct awareness training
IT Operations	Configure technical controls (lockouts, timeouts, MFA enforcement), manage Bitwarden infrastructure, patch authentication systems
Department Managers	Ensure team compliance, verify access requests, support training attendance, report suspicious activity
All Employees	Create compliant passwords, use Bitwarden, enable MFA, report incidents, complete annual security training
HR Department	Coordinate access revocation during termination, verify contractor status updates
Compliance/Audit	Validate adherence to PCI-DSS, SOX, FFIEC requirements; coordinate external audits
Third-Party Vendors	Comply with vendor agreement security clauses; provide attestation of compliance annually

5. Compliance

5.1 Monitoring

Compliance monitoring occurs through multiple channels:

- **Automated:** Weekly scans of password complexity violations via identity provider reports
- **Real-time:** Failed login attempt alerts to SOC dashboard; unusual geographic access patterns flagged
- **User Activity:** Bitwarden usage metrics tracked; accounts without MFA enabled identified monthly
- **Audit Logs:** All authentication events logged to SIEM; retention period: 3 years (PCI-DSS requirement)

5.2 Reporting

- **Daily:** Security Operations Center receives summary of authentication anomalies
- **Monthly:** Compliance dashboard sent to IT Director and CISO showing MFA adoption rates, lockout statistics, Bitwarden coverage
- **Quarterly:** Formal compliance report presented to Executive Security Committee including PCI-DSS control status
- **Immediate:** Potential policy violations or security incidents reported within 2 hours to security@securebank.example.com or SOC hotline

5.3 Auditing

- **Internal:** Annual internal audit covering password controls, MFA deployment, Bitwarden administration access
- **External:** PCI-DSS Qualified Security Assessor (QSA) assessment annually; FFIEC IT examination every 1-2 years
- **Evidence Collection:** Screenshots, configuration exports, audit logs maintained as proof of compliance
- **Gap Remediation:** Any findings must be remediated within defined timelines based on severity (Critical: 30 days, High: 90 days)

6. Enforcement

6.1 Violations

Violations of this policy may result in disciplinary action based on severity, intent, and impact:

Severity Level	Examples	Potential Actions
Minor	First-time failure to enable MFA; using weak password once	Verbal warning; mandatory retraining
Moderate	Repeated non-compliance; sharing credentials without authorization; disabling security features	Written warning; temporary access restrictions; performance review impact

Severity Level	Examples	Potential Actions
Serious	Intentional circumvention of controls; providing credentials to unauthorized parties; attempting unauthorized access	Suspension of access privileges; final written warning; potential termination
Critical	Malicious credential theft; creating backdoor accounts; selling/buying credentials	Immediate termination; potential legal prosecution; law enforcement notification

Additional consequences apply to third-party vendors per contract terms; persistent violations may result in contract termination.

6.2 Reporting Violations

Suspected violations should be reported through:

- **Primary Channel:** security@securebank.example.com
- **Phone:** SOC Hotline (+1-555-XXX-XXXX) — available 24/7
- **Whistleblower Portal:** anonymous reporting via <https://ethics.securebank.example.com> (third-party managed)
- **Manager Escalation:** If initial reporting yields no response within 48 hours

All reports handled confidentially; retaliation against reporters prohibited under Company Ethics Policy ETH-002

7. Exceptions

7.1 Exception Process

Exceptions to this policy require formal documentation and approval:

1. **Written Request:** Submit via ticketing system (security-request@securebank.example.com) to CISO
2. **Business Justification:** Detailed explanation of why policy creates operational barrier
3. **Risk Assessment:** Quantitative risk analysis performed by Information Security team
4. **Compensating Controls:** Alternative security measures that achieve equivalent protection
5. **Formal Approval:** Requires signatures from Policy Owner (CISO) AND affected Business Unit Head for high-risk exceptions
6. **Documentation:** All exceptions recorded in Exception Register with unique tracking ID

7.2 Exception Duration

- **Temporary Exceptions:** Maximum 90 days; auto-expiring unless renewed
 - **Permanent Exceptions:** Require annual re-evaluation; documented rationale in Exception Register
 - **Review Cadence:** All active exceptions reviewed quarterly by Security Architecture Review Board
 - **System Decommission:** Exceptions automatically revoked when related system retired
-

8. Definitions

Term	Definition
Authentication	Verification of claimed identity through credentials or biometric factors
MFA (Multi-Factor Authentication)	Authentication using two or more independent verification methods
OAuth2	Open standard authorization protocol enabling secure delegated access
OIDC (OpenID Connect)	Identity layer built on OAuth2 providing authentication capabilities
Passphrase	Sequencing multiple words to create memorable yet strong credentials
Privileged Account	Account with administrative rights above standard user permissions
Salt	Random data added to password before hashing to prevent rainbow table attacks
TOTP	Time-based One-Time Password algorithm used in authenticator apps
SIEM	Security Information and Event Management system for centralized log collection
PAM	Privileged Access Management—a security discipline controlling elevated access

9. Related Documents

- **POL-SEC-002:** Multi-Factor Authentication Technical Standards
 - **POL-SEC-003:** Privileged Access Management Policy
 - **STD-001:** Bitwarden Enterprise Configuration Standards
 - **STD-002:** Identity Provider (IdP) Integration Guidelines
 - **PROC-001:** Incident Response Procedure
 - **FRC-PCI-DSS-v4.0:** Payment Card Industry Data Security Standard Framework Reference
 - **NIST SP 800-63B:** Digital Identity Guidelines
 - **FFIEC CAT:** Cybersecurity Assessment Tool
 - **SANS Password Policy Best Practices**
-

10. Revision History

Version	Date	Author	Description
1.0	2026-06-22	InfoSec Team	Initial release; aligned with NIST SP 800-63B and PCI-DSS v4.0

11. Acknowledgment

By accessing SecureBank systems, all users acknowledge they have read, understood, and agree to comply with this policy.

For formal acknowledgment tracking, use the Company Policy Management System at:
<https://policy.securebank.example.com/acknowledge/POL-SEC-001>

Individuals who fail to acknowledge this policy within 14 days of effective date or policy revision will have system access restricted until acknowledgment is completed.

Contact Information

Policy Questions: security-policy@securebank.example.com
Technical Support: it-helpdesk@securebank.example.com
Emergency Security Issues: soc@securebank.example.com or +1-555-XXX-XXXX
Bitwarden Specific: bitwarden-admin@securebank.example.com (Identity & Access Management Team)

This document contains SecureBank internal proprietary information. Unauthorized distribution prohibited.

Appendix A: Technical Standards Reference

Per policy, detailed technical specifications reside in separate standards documents. Key implementation parameters:

Control	Standard Document
Bitwarden Organization Settings	STD-001 Sec 3
OAuth2 Token Lifecycle	STD-002 Sec 5.2
Password Hashing Algorithms	STD-001 Sec 4.1
MFA Fallback Procedures	POL-SEC-002 Sec 6
Session Management	STD-002 Sec 3
